Implementation of a Security Information and Event Management (SIEM) Solution for a Mid-Sized Retail Business

Sara E. Goodie

Western Governors University

Table of Contents

Proposal Overview 3
Problem Summary 3
IT Solution 4
Implementation Plan 5
Review of Other Work 8
Summary of Four Works 9
Relation of Works to Proposal Design 11
Project Rationale 11
Current Project Environment 12
Methodology 15
Project Goals, Objectives, and Deliverables 18
Goals, Objectives, and Deliverables Descriptions 18
Goals, Objectives, and Deliverables Table 19
Project Timeline with Milestones 20
Outcome 21
References ..... **Error! Bookmark not defined.**

Proposal Overview

Problem Summary

The business is a retail business with an estimated 200 employees with both physical and online sales operations. The problem was a recent phishing incident that led to an account being compromised which revealed that the company lacks centralized visibility in its IT environment. Currently all the firewalls, servers, and workstations are working independently and not correlated to each other whatsoever. This lack of visibility quickly increases the risk of data breaches, financial losses, and repeated harm to the company.

IT Solution

The solution is to implement a Security Information and Event Management (SIEM) platform, such as Microsoft Sentinel or Splunk, that will address the business's lack of visibility across its IT environment. A SIEM provides a unified system for collecting, analyzing, and correlating data from all key IT assets, including endpoints, firewalls, cloud resources, and authentication systems. This is all centralized, which provides easier visibility and access, thereby mitigating the business's phishing incidents. The lack of monitoring lets abnormal account activity and lateral movement attempts become successful.

A SIEM functions by collecting raw log data from multiple sources, including API-based connectors. These logs are then converted into a common format, which is compared with threat intelligence feeds, user behavior, analytics, and other relevant data. Once the data is aggregated, the SIEM analyzes it in real-time, allowing for the identification of suspicious events, such as repeated login failures, malware execution, and anomalous network traffic. The SIEM also features integrated alerts and automatic actions, which help the IT team respond quickly to active threats.

The SIEM also provides dashboard views for security posture monitoring, with automated correlation rules that help identify attack chains that would go unnoticed, as well as log saves for forensic investigations. By blending systems such as Active Directory, endpoint detection, firewalls, VPN logs, and cloud services, the SIEM establishes a solid foundation for the enterprise monitoring capabilities that the organization lacks.

Rather than relying on manual incident review, the business could benefit from a centralized monitoring platform that aligns with modern cybersecurity practices. SIEM supports regulatory compliance requirements (like PCI-DSS), providing auditable logs, incident reporting capabilities, and continuous monitoring of systems that process payment data. SIEM offers an end-to-end solution that enhances visibility. It's an effective technical solution that prevents the recurrence of the type of compromise the organization experienced and more.

Implementation Plan

The implementation plan will be a structured and phased deployment plan to ensure a smooth rollout. This allows us to ensure accurate reporting, minimize operational disruption, and verify each component before moving into production. This plan explains the team's responsibilities, component configuration, required actions, and expected outcomes for each step.

1. Planning (IT director & Security Lead): In this phase, leadership is an important component of the project due to defining the overall scope of the project as well as objectives and success criteria. The IT director selects the best-suited SIEM platform for their environment, like Microsoft or Splunk. What determines that is the cost, integration capabilities, and licensing requirements. The Security Lead oversees all types of log requirements, including endpoint systems, firewalls, domain controllers, cloud services, VPN appliances, and point-of-sale systems. The planning phase also includes timelines, assigning responsibilities, and determining the network and storage capacity needed to support SIEM. Finally, data retention is established to meet both operational needs and regulatory requirements, including those outlined in PCI-DSS.

2. SIEM Deployment in Test Environment (System Administrators): Before actual deployment, System Administrators are required to install and configure a SIEM platform in a controlled sandbox environment. This will include preparing virtual machines/cloud resources, establishing initial ingestion pipelines, and configuring network access. For cloud SIEM solutions like Sentinel, System Administrators are required to configure the log analytics workspace and assign access roles. This phase will enable a thorough review of various installations, including bandwidth, agent deployment methods, and compatibility with current security tools, to ensure they integrate seamlessly before being introduced to SIEM production environments.
3. Log Sources Integration (Security Engineers): In order for the SIEM to begin ingesting, Security Engineers start to connect log sources to the SIEM. This includes Active Directory domain controllers, cloud (Microsoft 365), application servers, email security gateways, endpoint detection, and firewalls. These engineers configure data connectors, install needed SIEM agents, and ensure the log formats are properly enforced. During this phase, it's essential to monitor the ingestion health to ensure events are arriving in a consistent and accurate manner. Engineers are also required to implement intelligence sources and correlation packs provided by the vendor to enhance detection capabilities.

4. SIEM Configuration and Use-Case Development (Security Team): Once the log sources are all set up and integrated, the Security Team configures dashboards, analytics rules, and alerting mechanisms. The rule functions are developed to detect phishing indicators, credential abuse, unusual login attempts, lateral movement, privilege escalation, and anomalous network traffic. They can customize dashboards for executive reporting, long-term trend analysis, and real-time incident monitoring. There are also automated response playbooks that can be configured to trigger containment actions, such as disabling compromised accounts or blocking malicious IP addresses. This phase makes sure that the SIEM is organized enough to take meaningful actions.
5. Testing and Validation (IT & Security Teams): The IT and Security Team will work together to conduct testing, as well as make sure the alerts function as intended. Controlled simulations are performed, such as phishing attempts, privilege escalation, suspicious file activity/network activity, and failed logins. With these tests, each alert is validated for timeliness, accuracy, and correlation across multiple log sources. It is possible for false positives to occur, which will be documented, and the rules adjusted accordingly. The goal of this phase is to ensure the SIEM provides reliable and accurate detections during incident response. Both teams will submit a final validation report to finalize the production process.

6. Training (Security Lead & HR): This is one of the most important phases to avoid human error when working with these systems. Before rollout, all staff across IT and security teams will undergo training that covers how to navigate SIEM, interpret dashboards, respond to incidents, and triage alerts. There will be training materials, such as video guides, usage documents, and incident response playbooks, tailored to the organization. HR could assist in scheduling workshops and ensuring the completion of the training. This phase ensures that all personnel are ready to operate SIEM once it's deployed.

7. Production Rollout and Continuous Improvement (All IT Teams): After all the successful testing, the SIEM is moved into full production. Log ingestion is switched from tests to live environments, and the SIEM will begin continuous monitoring. The IT and security teams will continually refine their alerts to enhance accuracy and reduce false positives. As the environment evolves, additional log sources will be added. Monthly reviews are conducted to monitor system performance, track incident response metrics, and analyze detection trends. This is all aimed at continuous improvement and ensures the SIEM remains aligned with business needs.

8. A3a. Justification

The phased implementation is compatible with working because it minimizes risk by making sure each stage is validated before full deployment. Testing ensures accuracy of alerts, staff training ensures operational readiness, and assigning specific roles to IT staff takes advantage of existing expertise, ensuring accountability and smooth adoption.

Review of Other Work

Summary of Four Works

Work 1 – NIST SP 800-137 (Information Security Continuous Monitoring): The NIST SP 800-137 establishes the federal standard for managing and creating the Information Security Continuous Monitoring (ISCM) program. The purpose of this publication is to state that for organizations to maintain awareness of vulnerabilities, threat activity, and network behavior, they should collect security data from all critical assets into a centralized monitoring system (NIST, 2011). NIST also explains that manual log reviews can produce delayed detection and incomplete analysis, which increases the exposure time for attackers. NIST emphasizes that automated correlation, standardization of log formats, and enterprise visibility are all core functions of a SIEM. This directly relates to the project because the business currently has a deficiency in centralization, specifically in log management and correlation capabilities. And these are things NIST preaches as essentials in a successful security posture. By implementing a SIEM, the business will align with NIST standards and continue to strive for automated and continuous monitoring.

Work 2 – Verizon Data Breach Investigations Report (DBIR, 2023): In 2023, the Verizon DBIR provided an annual report of breach patterns across multiple industries; it is one of the most widely referenced for cybersecurity studies. The DBIR told us that phishing remains one of the top initial access vectors, and stolen credentials accounted for a significant percentage of breaches globally (Verizon, 2023). One of the key findings is that organizations often fail to detect breaches promptly due to a lack of centralized logging and delayed review of separate systems. The report demonstrates that most compromises occur before detection, which increases the damage and cost of these incidents. The DBIR states that with automated detection

technology, such as SIEMs, it is possible to identify breaches more quickly than relying on manual methods. This idea brings us back to the need for SIEM in this business; the phishing incident could have been detected early if automated alerting and detection were in place.

Work 3 – IBM Cost of a Data Breach Report (2023): The IBM Cost of a Data Breach Report is based on an analysis of thousands of real-world data across multiple sectors. The 2023 report found that the average breach costs millions of dollars, but organizations using security analytics, which include SIEM and SOAR solutions, lowered the cost of breaches by an average of 30% (IBM Security, 2023). IBM calculated these savings using Mean Time to Detect (MTTD) and Mean Time to Contain (MTTC), which are derived from the outcomes of centralized monitoring and automated alerts. The report also points out that organizations with separate or immature monitoring programs experience an increase in breach costs because of longer dwell times. This directly relates to the project because the business currently lacks real-time visibility, manual log review, and a correlation engine, which a SIEM will address to resolve these issues. IBM's findings suggest that the investment will provide measurable financial and operational benefits.

Work 4 – Splunk Whitepaper on Security Analytics (2022): The Splunk Security Analytics whitepaper discusses how SIEM platforms aggregate logs from cloud applications, endpoints, servers, firewalls, and identity systems into a centralized environment. The whitepaper explains that SIEM correlation rules assist analysts in identifying multi-step attacks, such as phishing with credential abuse or lateral movement (Splunk, 2022). Splunk also mentions machine learning anomaly detection, customizable dashboards, and automated response capabilities for high-risk alerts. All these benefits address the business's issue of having isolated systems with no unified visibility or automated alerting. The whitepaper provides technical guidance for selecting a

SIEM solution and demonstrates the practical improvements a business can expect in threat detection speed, analysis speed, and incident response coordination.

Relation of Works to Proposal Design

All four reviewed works helped support the proposed solution for the business by providing authoritative evidence, industry trends, and technical justification for the implementation of SIEM. NIST SP 800-137 set the stage for the need for continuous monitoring, standardization of log management, and automated correlation, which later became the foundation for selecting SIEM as the main technology (NIST, 2011). The Verizon DBIR confirmed the urgency of this solution by demonstrating that phishing and credential abuse remain the top causes of breaches, and that organizations that are slow to detect are disproportionately impacted (Verizon, 2023). The IBM Cost of Data Breach Report contributed a financial perspective, showing that organizations that use SIEM reduce incident costs through quicker detection (IBM Security, 2023). Lastly, the Splunk whitepaper presented the technical aspects, helping define how log ingestion, dashboarding, correlation, and automated alerts would support the operational workflow (Splunk, 2022). All these works together provided both strategic and technical elements of the proposed SIEM solution and showed us strong evidence for its benefits.

Project Rationale

The Implementation of a Security Information and Event Management (SIEM) platform is important for the business because it addresses the critical vulnerabilities shown by the recent phishing incident. From a business perspective, the organization currently handles sensitive

customer information, including payment card data, in both retail locations and online platforms. Handling this information, the company must adhere to industry regulations, such as PCI-DSS, which require centralized logging, log retention for systems that store cardholder data, and regular monitoring of those systems. Currently, the logs are stored separately and reviewed inconsistently, which doesn't meet the PCI-DSS requirements. Adding a SIEM to the business will help satisfy regulatory expectations by ensuring logs are collected, analyzed, protected, and audited in a standardized manner. Additionally, with the increasing demand driven by online presence, businesses will expand in this area, further broadening the threat landscape. The more the company grows, manual log review will become insufficient for detecting modern cyber threats. SIEM can automate this process, making it easier to detect attacks quickly and respond just as fast. SIEM also supports trend analysis for long-term incident response workflows and aids with forensic investigations. All of this will help the business be resilient against evolving threats. Lastly, a SIEM aligns with the business's idea to maintain customer trust and maintain uninterrupted business operations. The moment a breach rears its head, involving customer or payment information, could cause reputational and legal damage, as well as erode customer trust. By enhancing detection capabilities and reducing response times, SIEM lowers the likelihood of impact from future breaches. Increased visibility also enables leadership personnel to make informed security decisions based on the required data, thereby supporting long-term organizational goals.

Current Project Environment

The current project environment operates within a mixed IT environment that includes both in-person retail stores and an online sales platform. The infrastructure consists of multiple separate systems for HR, point of sale (POS), sales management, customer service, and inventory control. These systems generate important operational and security logs, which are stored and reviewed independently on an as-needed basis. This approach isn't consistent with creating visibility across the environment and makes it difficult for the security team to detect multi-stage attacks. The business uses cloud services like Microsoft 365, POS terminals, endpoint devices, Windows servers, and firewalls. All these systems produce logs that are labeled for authentication, network traffic, user behavior, and application activity. Even though these sources are available, they're not collected or correlated on a centralized system. For example, when a failed repeated login attempt happens on the domain controller, the failed attempts are not compared with suspicious network activity detected by firewalls. Due to this, indicators of compromise won't be detected. Moreover, from a staffing perspective, the IT department is familiar with Microsoft 365, remote VPN access, and endpoint management solutions. This means that the technical staff can support a cloud-based SIEM, such as Microsoft Sentinel, or a hybrid deployment model using Splunk. However, currently, the required security is for reactive operations. Their alerts are limited, reports are generated manually, and there is no incident response structure in place supported by real-time monitoring. Additionally, each system handles logs over different time periods. Some are even deleted or overwritten, causing evidence to disappear before anybody can review it or investigate what might have happened. The business network doesn't have a unified monitoring layer. There are no automated mechanisms in place to correlate/detect logs; all their systems, like their servers, POS, and firewalls, operate separately. This fragmented environment is what

caused the phishing incident in the first place, allowing no middle ground for these logs to be flagged for unusual account activity or correlated with external log attempts. The business is also expanding its online presence, as well as its retail operations, so the amount of data and assets requires a more scalable monitoring method that meets operational demands. This lack of visibility at this scale poses compliance challenges as well with PCI-DSS, which requires consistent real-time monitoring, log retention, and documentation for payment systems. The implementation of SIEM will improve visibility, automate alerting, and provide a scalable and unified foundation that supports the future growth of this business.

Methodology

The Agile methodology supports iterative development, flexibility, and continuous improvement throughout the SIEM implementation, which is what this project will utilize. Agile complements security-focused projects because they involve the ongoing refinement of alert rules, dashboards, detection use cases, and log integrations, which are also requirements for SIEM deployments. Agile is also flexible enough to adapt to new security requirements or detection gaps during testing. The Agile approach consists of multiple divided short sprints; each sprint is a functional puzzle piece to the SIEM project. It's easier to detect early problems this way and add adjustments based on the findings of each sprint, allowing incremental progression. Agile's emphasis on collaboration aligns well with the versatile nature of SIEM deployments, as it requires coordination among system administrators, security engineers, analysts, and leadership.

Steps:

Sprint 1 – Deployment and Initial Configuration

The first sprint focuses on installing the SIEM platform in a test environment and configuring the foundational components. This means establishing the SIEM workspace, setting ingestion pipelines, deploying agents, and verifying basic system functionality. At the end of this sprint, the team analyzes performance metrics based on ingestion rate, storage usage, and connectivity to ensure the platform has a solid foundation for further expansion.

Sprint 2 – Log Source Integration and Normalization

The second sprint involves security engineers integrating essential log sources that include domain controllers, servers, POS systems, firewalls, cloud applications, and endpoint devices. Each data source is mapped to the right schemas for normalization. This sprint enables the team to identify errors in data formatting, ingestion delays, or misconfigurations early on, thereby preventing later issues from spreading when production begins to roll out.

Sprint 3 – Alert Creation, Dashboard Development, and Use-Case Testing

Sprint 3 involves configuring the SIEM to provide actionable intelligence. The security team can build automatic alerts, dashboards, detection rules, and correlation logic to identify threats such as phishing, credential abuse, and suspicious network and login behavior. The team conducts controlled tests to verify alert accuracy, refining thresholds and minimizing false positives as much as possible. These iterative cycles allow for quick feedback and continuous refinement until this step is optimized.

Sprint 4 – Training, Documentation, and Incident Workflow Development

Sprint 4 focuses on preparing the IT staff on how to operate the SIEM effectively. The team creates user documentation, dashboard guides, and training materials to support users. Workshops are also available with analysts, IT technicians, and security personnel to demonstrate how to investigate alerts, interpret dashboards, and use automated workflows. Feedback from this sprint is essential, as it helps improve both training materials and system configurations.

Sprint 5 – Production Rollout and Continuous Improvement

This final sprint transitions the SIEM into the production environment. Monitoring becomes part of daily operations; log sources are connected to live systems, and real-time alerting is activated. The nature of Agile supports small ongoing improvements to existing processes. As a result, Sprint 5 includes ongoing optimizations, such as adding new detection rules, log sources, and adjusting alert thresholds. Continuous improvement makes sure that the implemented SIEM adapts to new or existing threats.

Project Goals, Objectives, and Deliverables

Goals, Objectives, and Deliverables Descriptions

The project has three primary goals, supported by specific objectives and deliverables. These goals align with the organization's need for enhanced threat detection, improved operational readiness for SIEM operations, and centralized visibility.

Goal 1: Centralize Security Monitoring Across the Organization

Supporting Objective 1.1 – Connect all critical log sources to the SIEM

- Deliverable: A fully deployed SIEM environment with data connectors configured for authentication systems, cloud services, POS systems, firewalls, endpoints, and servers. This deliverable provides the foundation for centralized visibility by ensuring that every major system integrates security data into a single monitoring platform.

Supporting Objective 1.2 – Normalize and correlate all ingested log data

- Deliverable: A functional SIEM configuration with parsing rules, normalization schemas, and correlation logic for different types of logs. This ensures that data from different systems is properly organized and can be correlated to identify specific attacks.

Goal 2: Improve Threat Detection and Incident Response Capabilities

Supportive Objective 2.1 – Develop detection rules, dashboards, and automated alerts for threats

- Deliverable: Customized dashboards and alerting rules that are designed to identify phishing indicators, suspicious account activity, malware events, and failed login patterns. This deliverable enables the real-time detection of threats that were previously undetected.

Supporting Objective 2.2 – Validate detection logic through simulated attacks

- Deliverable: A fully developed test report documenting the results of simulated testing incidents, false positives, rule refinements, and alert accuracy. This ensures the SIEM is reliable in identifying threats and supports a quick incident response.

Goal 3: Prepare IT Staff to Use and Maintain the SIEM

Supportive Objective 3.1 – Provide structured training to IT and security personnel

- Deliverable: User guides, training materials, and incident response playbooks that have SIEM workflows, dashboard usage, and an investigation procedure for alerts. This will aid staff with the steps to operate and maintain SIEM after deployment.

Supportive Objective 3.2 – Conduct workshops and evaluate staff

- Deliverable: Attendance records, completed workshop sessions, and staff evaluation all demonstrate the readiness of using SIEM in daily operations. This will make sure the business personnel can manage the platform long-term.

Goals, Objectives, and Deliverables Table

	Goal	**Supporting Objectives**	**Deliverables Enabling the Project Objectives**
1	**Centralize Security Monitor**	Collect logs from servers, endpoints, and firewalls	
			Installed SIEM with configured log connectors
		Normalize and correlate log data	
			Functional SIEM environment with normalized logs

2	**Detect & Respond to Threats**	Create dashboards and alert rules	
			Customize dashboards and automate alert systems
		Validate alerts with test incidents	
			Test reports from simulated attacks
3	**Staff Training**	Develop training documentation	
			Training manuals and incident response playbooks
		Staff workshops	Staff evaluations and completed training sessions

Project Timeline with Milestones

Milestone	**Duration (hours or days)**	**Projected Start Date**	**Anticipated End Date**
Install SIEM in test environment	3 days	December 1, 2025	December 3, 2025
Collect log sources	5 days	December 4, 2025	December 9, 2025
Configure dashboards and alerts	7 days	December 10, 2025	December 17, 2025
Testing and feedback	4 days	December 18, 2025	December 21, 2025
Staff training	3 days	December 22, 2025	December 24, 2025
Production rollout	5 days	December 25, 2025	December 30, 2025

Outcome

The outcomes of this project will demonstrate measurable improvements in visibility, threat detection, and staff readiness following the implementation of SIEM. These outcomes will be analyzed using system metrics, user performance data, and testing results.

Outcome 1: Centralized Log Collection from All Critical Systems

The first outcome will be the successful aggregation of all security logs from various systems, including servers, firewalls, endpoints, POS devices, and cloud applications, directly into the SIEM platform.

Data Collected:

- Ingestion dashboards showing data flow that is active
- Log source connection status
- Normalization reports

Success Criteria:

- Critical log sources are connected and sending data consistently at 100%
- During the validation period, there are no ingestion gaps or parsing errors

Outcome 2: Accurate Detection of Simulated Security Incidents

Another outcome is improved threat detection, shown through controlled testing, like phishing simulations, unauthorized access, failed login attempts, and anomalous network activity.

Data Collected:

- Alert timestamps

- Correlation accuracy reports
- False negative and false positive counts

Success Criteria:

- Minimal false positives
- High detection and correlation rules accuracy
- Alerts triggered within expected timeframes

Outcome 3: Staff Demonstrate Proficiency in SIEM Monitoring and Incident Response

The final outcome is that the IT and security staff can demonstrate their ability to successfully operate the SIEM and respond to alerts, having completed all necessary training and workshops.

Data Collected:

- Workshop/training records
- Hands-on demonstration results
- Self-assessment surveys and post-training evaluations

Success criteria

- 90% of trained staff score high on evaluations
- Positive staff feedback of improved confidence in handling SIEM alerts
- Staff can follow SIEM workflows during simulated incidents

References

IBM Security. (2023). *Cost of a data breach report 2023*.
https://www.ibm.com/security/data-breach

National Institute of Standards and Technology. (2011). *NIST SP 800-137: Information security continuous monitoring (ISCM) for federal information systems and organizations*.
https://doi.org/10.6028/NIST.SP.800-137

Splunk. (2022). *Security analytics and SIEM: Whitepaper on modern security operations*.
https://www.splunk.com

Verizon. (2023). *2023 data breach investigations report*.
https://www.verizon.com/business/resources/reports/dbir/